



JAMAICA CONSTABULARY FORCE
NPCJ IT Security Policy and Standard Operating Procedures

Title: NPCJ I.T Security Policy and Standard Operating Procedures	JCF/NPCJ-IT/PL/SFs/0007/2023
Effective Date: 2025-Apr-3	Pages: 55
Review Date: 2025-Apr-1	Distribution: NPCJ
Revision#: 1	Process Owners: ACP NPCJ
Rescinds: 2023-May-05	
Authors: NPCJ, I.T Department	Owner: JCF
First Published: 2023-May-05	Review: Triennially

Table of Content

1	Introduction	5
2	Purpose	5
3	Scope	8
4	Abbreviations and Acronyms	8
5	Definitions.....	9
6	Responsibilities.....	13
7	Policy Statement	13
8	Standard Operating Procedures	14
8.1	Security Incident Management.....	14
8.1.1	Preparation & Protection against Security Incidents	14
8.1.2	Security Incident Detection & Reporting	15
8.1.3	Security Incident Analysis & Escalation.....	16
8.1.4	Security Incident Handling	17
8.1.5	Post Security Incident Review	17
8.2	Vulnerability Management	18
8.2.2	Ongoing assessment to identify vulnerabilities	20
8.2.3	Monitoring the effectiveness of operational security measures.....	21
8.3	Anti-Virus and protection from malicious code or network traffic	21
8.4	Cryptography	23
8.4.1	Cryptographic Keys Management	24
8.4.2	Data Masking	25
8.4.3	Implementation of Data Masking.....	25
8.4.4	Cryptographic and Masking Algorithms.....	26

8.5	User Controls	26
8.5.1	Access Control	26
8.5.2	General Access Provisioning and De-provisioning	26
8.5.3	Generic Accounts	27
8.5.4	Remote User Access	28
8.5.5	Federated User Access	28
8.5.6	User Accountability	29
8.5.7	Account Management	29
8.5.8	Password management	30
8.5.9	Privileged User Access Management	31
8.5.10	Functional accounts	32
8.5.11	System accounts	32
8.5.12	General	32
8.6	Web Application Security	33
8.6.1	Security principles for web applications	33
8.6.5	Build - development of web applications	35
8.6.6	Test - Security testing of web applications	36
8.7	Physical Security	36
8.7.1	Cabling Security	36
8.7.2	General workplace security	37
8.7.3	Controlling access to secure areas & buildings (equipment room)	37
8.7.4	Controlling incoming and outgoing objects	38
8.7.5	Server Room Security	38
8.7.6	Controlling access to Server Room	39

8.8	Bring Your Own Device (BYOD)	41
8.8.1	NPCJ's Responsibilities (Standards)	41
8.8.2	Bring Your Own Device - Notebook or Laptop Computers (Guidelines)	42
8.8.3	Portable Storage Devices and Cloud Storage Solutions	43
8.8.4	Access to the Wi-Fi, Bluetooth and Wired networks	44
8.9	Network Security	44
8.9.1	Security Principles	44
8.9.2	Network Diagrams	46
8.9.3	Virtualisation	47
8.9.4	Firewalls	48
8.9.5	Intrusion Prevention	49
8.9.6	Gateway and WAN Edge Connectivity	50
8.9.7	Connections to un-trusted and third-party networks	51
8.9.8	Security of core network services	51
8.9.9	Network Time Protocol	51
8.9.10	Secure network management	52
8.9.11	Network configuration management and integrity checking	53
8.9.12	Security of wireless networks	53
8.9.13	Security of Voice over IP (VoIP) networks	54
9	Legislative Authority/Guiding Principles	55
10	Relevant records and Forms	Error! Bookmark not defined.
11	Roles and functions	Error! Bookmark not defined.

1 Introduction

The National Police College of Jamaica (NPCJ) recognizes the importance of information technology in advancing the organization's purpose. In this regard, the information of the National Police College of Jamaica (NPCJ), whether controlled and stored on NPCJ resources or held in trust and handled by third parties or commercial partners, is a valuable asset that must be safeguarded.

Any individual or organization who utilizes or maintains these assets in trust has a responsibility to keep them safe and secure.

Regardless of whether information is electronic or non-electronic, the organization is dedicated to maintaining its confidentiality, integrity, and availability. Improper use of information resources could jeopardize the organizational efforts and impact the Jamaica Constabulary Force (JCF) at large.

2 Purpose

2.1. Security Incident Management

Information security controls that are appropriate lower the likelihood and effect of security incidents. The goal of this standard is to lay down the groundwork for dealing with information security incidents in a timely and effective manner.

A suspected or proven breach of the integrity, availability, or confidentiality of NPCJ IT assets is referred to as an information security incident. NPCJ could suffer financial, availability, or reputational harm as a result of an information security breach. Intentional (planned activities against information) or unintentional actions can cause security incidents. Any violation of the NPCJ's IT Security Policy is considered an information security incident.

2.2. Data Security

During various stages of the data lifecycle, appropriate data security procedures lower the risk (and impact) of data breach occurrences. This standard establishes the standards for protecting NPCJ data during transmission and storage.

2.3. Vulnerability Management

Security vulnerabilities on operating systems, applications, and devices must be managed as part of NPCJ's security. The majority of cyber-attacks aim to exploit well-known flaws in out-of-date equipment and software.

This standard establishes the minimum standards for managing vulnerabilities and defending against malicious software in order to minimize the risk to NPCJ IT systems and information's confidentiality, integrity, and availability.

2.4. User Access

User access must be provided according to the principles of “least privilege” and “need to know” required for achieving the desired function. The purpose of this Standard is to set out the rules under which access to NPCJ information systems are provided, controlled and managed.

NPCJ has established and follows specific access control practices to protect their information and systems from unauthorised access; modification, disclosure or destruction and to ensure that information remains accurate, confidential, and is available when required. Information systems include:

- Operating Systems.
- Applications.
- Databases.
- IT services such as Internet and email.
- Network Equipment (e.g., firewalls, routers, switches etc) and infrastructure appliances.

2.5. Web Application Security

The security of web applications is critical to the overall security of the NPCJ environment. Web-based protocols are the subject of emerging and ongoing threats, and if exploited may expose sensitive NPCJ information (i.e. subject to either legislative or regulatory requirements) to compromise.

The purpose of this standard sets out the baseline requirements for the design, build and test of web applications in order to reduce the risk to NPCJ of any compromise of the web applications, the information stored within, or connected IT systems and networks.

2.6. Physical Security

Robust physical and environmental controls must exist to protect information assets and systems from unauthorised access, and safeguard against environmental threats. This Standard sets out the rules for the protection of information systems from physical and environmental threats to ensure the confidentiality, integrity, and availability of the data contained within the physical environment.

2.7. Bring Your Own Device (“BYOD”)

Bring Your Own Device, (“BYOD”) programs are becoming increasingly popular as they give employees the opportunity to choose and purchase their own IT equipment, for both business and personal use. This document defines recommendations and requirements of use, when connecting personally owned devices to the NPCJ network.

NPCJ supports BYOD, allowing staff and students to purchase personal mobile computing device(s) of their choice and access NPCJ’s IT systems. This document applies to, but is not limited to the following devices:

- Smart phones.
- Tablet computers.
- Notebook computers.
- Laptop computers.
- Portable storage devices.

Given the changing landscape of BYOD technologies, NPCJ must be aware of any new devices that could be used to connect to NPCJ network. BYOD devices pose a risk to NPCJ information technology systems if not properly managed and should be controlled by the owner in accordance with the recommendations described in this document.

2.8. Network Security

The NPCJ network provides baseline connectivity between all end user, compute and storage devices. It also provides access between NPCJ and external networks, including both partner networks and the Internet. The information security controls which are deployed to the network are critical to the overall security posture of NPCJ, and failure of these controls may expose the confidential and sensitive information that NPCJ manages.

Network technology and topologies are evolving rapidly. This is observed in the rapid shift to virtualisation technology at the network layer as well as next generation network devices which can be solely responsible for multiple functions such as switching, routing, packet filtering, load balancing and traffic inspection. Specific care must be taken with such devices as a simple configuration error may have a detrimental effect on the security of the overall device, and

therefore the networks that it services. In alignment with this rapidly evolving lifecycle, network security controls must be adjusting to accommodate this new functionality and services.

Consequently, Network Security controls must not constrain the ability of NPCJ to innovate, but should give a framework of controls which allows NPCJ to access new and innovative services in a secure controlled manner.

This standard aims to ensure that NPCJ networks are designed, implemented and managed according to good practice security standards in order to protect the NPCJ data and IT services, whilst allowing NPCJ to utilise innovative and evolving technologies.

3 Scope

Personnel (including casuals), students, consultants and contractors, third parties, agency staff, alumni, associates, conjoint appointments, and visitors to the College are all covered by this standard.

4 Abbreviations and Acronyms

JCF	Jamaica Constabulary Force
NPCJ	National Police College of Jamaica
ICTD	Information Communication & Technology Department
ACP	Assistant Commissioner of Police
JaCIRT	Jamaica Cyber Incident Response Team
OWASP	Open Source Foundation for Application Security
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
SIEM	Security information and event management
SQL	Structured Query Language
OS	Operating System
LAN	Local Area Network
WAN	Wide Area Network

5 Definitions

Breach	1. Any confirmed disclosure of Institutional Information to an unauthorized party. 2. Unauthorized acquisition of information that compromises the security, confidentiality, or integrity of Institutional Information maintained by NPCJ.
Critical IT Infrastructure	1. IT Resources that manage unrelated sets of Institutional Information or sets of large or particularly sensitive Institutional Information. 2. IT Resources that meet two conditions: a) Several information systems rely on the resource such that a security issue with the resource would affect multiple systems. b) The default or standard method for securing the system is inappropriate due to an elevated level of risk, complexity, or the specialized nature of the IT Resource. Example 1: Active Directory, which maintains information about users, permissions, and other security-related attributes, is considered Critical IT Infrastructure.
Delete	A disposal process that removes the ability to access the respective file, record, or data in the operating system or application. Example 1: On a Windows or MacOS device, a user deletes a file by moving it to the trash/recycle bin and then empties the trash. Example 2: In a relational database, using SQL TRUNCATE TABLE is a Delete.
Guideline	A collection of system-specific or procedure-specific recommendations for best practices. Guidelines are strongly recommended practices or steps, but are not required. Example 1: The Microsoft Windows hardening guide is a guideline.

	Example 2: A vendor's best practice guide for securing a system is a guideline
Hash (Hash Function)	A value computed from a cryptographic function that maps a string of characters of arbitrary length (passphrase + salt) to a fixed-length bit string (the hash value). Example 1: A function that can be used to map data of an arbitrary size to data of a fixed size, such as SHA-1 or SHA-256, is a Hash. Example 2: A function that can be used to map data of variable size to data of a fixed size, such as MD-5, is a hash.
Information Security Event (Security Event)	1. An identified occurrence in a system, service, or network state indicating a possible breach of information security policy, a failure of controls, or a previously unknown situation that may be relevant to security. 2. An alert or notification created by a person, IT service, configuration item or monitoring tool related to information security. These typically require IT operations personnel to investigate or act and can lead to an Information Security Incident (see definition below). Example 1: Antivirus software sends an alert when malware is detected. This is a security event. Example 2: Firewall logs show remote connection attempts from an unexpected location. These are security events.
Information Security Incident (Security Incident)	A compromise of the confidentiality, integrity, or availability of Institutional Information in a material or reportable way. A single event or a series of unwanted or unexpected information security

	events that have a significant probability of compromising business operations or threatening information security. Example 1: A stolen laptop that contains unencrypted, personally identifiable information is a Security Incident.
Institutional Information	A term that broadly describes all data and information created, received and/or collected by NPCJ. Example 1: Information contained in a database, such as employee personnel records or records pertaining to student enrolment and grades, is Institutional Information. Example 2: Activity log data from a server application or network device is Institutional Information. Example 3: Emails sent and received pertaining to NPCJ business are considered Institutional Information.
Integrity	The consistency, accuracy, and trustworthiness of data over its entire lifecycle. Example 1: An application administrator changes records to cover mistakes, causing a loss of integrity. Example 2: A technician makes changes to a report she wasn't authorized to access, causing a loss of integrity. Example 3: A storage device crashes and leaves files corrupted, causing a loss of integrity.
IT Resource(s)	A term that broadly describes IT infrastructure, software and/or hardware with computing and networking capability. These include, but are not limited to: portable computing devices and systems, mobile phones, printers, network devices, access control systems, digital video monitoring systems, data storage systems, data processing systems, backup systems, electronic media.

	This includes both NPCJ owned and personally owned devices while they store Institutional Information, are connected to NPCJ systems, are connected to NPCJ Networks, or are used for NPCJ business. Example 1: A Cisco firewall or switch installed in the building communications room is an IT Resource.
IT Team Member	A Team Member who is assigned specific information technology (IT) duties or responsibilities.
Least Privilege Access	The practice of limiting access to the minimum level that will allow normal functioning.
Service Provider	Organizations or groups providing specific IT services to the NPCJ.
Standard	1. A collection of specific and detailed requirements that must be met. 2. Requirements that specify the set of administrative, technical, or procedural controls necessary to meet the related policy.

6 Responsibilities

The following summarizes the key areas of responsibilities:

- 6.1. The Assistant Commissioner of Police i/c Training Branch shall facilitate communication to all NPCJ staff, students in training, course participants and visitors to the College the requirements as outlined in the policy.

The Assistant Commissioner of Police i/c Training Branch will be notified of all security incidents, steps being taken and impact on IT resources.

- 6.2. The Sub Officer i/c Information Technology, NPCJ shall investigate and report any information security incident.

The SO i/c IT shall report to the ACP Training as well as Officer i/c ICTD details of any incident and its possible impact.

The SO i/c IT shall conduct sensitization training of staff and students of the NPCJ.

7 Policy Statement

It is the policy of the JCF that members shall use information technology resources, including computers, software and systems, that are issued or maintained by the Department in a professional manner and in accordance with this policy.

7.1. Privacy Expectation

- 7.1.1 Members forfeit any expectation of privacy with regard to emails, texts or anything published, shared, transmitted or maintained through file-sharing software or any Internet site that is accessed, transmitted, received or reviewed on any department computer system.

- 7.1.2 The JCF reserves the right to access, audit and disclose, for whatever reason, any message, including attachments, and any information accessed, transmitted, received or reviewed over any technology that is issued or maintained by the Force, including the department email system, communication system, computer network and/or any information placed into storage on any department system or device.

- 7.1.3 However, the department may not require a member to disclose a personal username or password or open a personal social website, except when access is

reasonably believed to be relevant to the investigation of allegations of work-related misconduct.

8 Standard Operating Procedures

8.1 Security Incident Management

8.1.1 Preparation & Protection against Security Incidents

NPCJ has several Policies, Standards, and Guidelines in place to safeguard NPCJ from current and new security threats that could result in a data breach.

NPCJ uses certain security controls as part of its deployment to limit the possibility and effect of information security events. Specifically:

- **Information security risk assessment** – periodic risk assessments are required to identify information risks, analyse their likelihood and impact on NPCJ operations, and design suitable risk mitigation policies.
- **Information systems protection** – all NPCJ servers and end-user computer gear must be properly hardened using security updates/patches and anti-virus software.
- **Design and review of network architecture** - The network must be developed and configured securely. To guarantee that the network architecture is acceptable, it must be examined on a regular basis
- **IT system configuration health check reviews** - IT system and network component configurations must be examined to ensure that they comply with the system's Baseline Configuration and approved Request for Changes (RFCs).
- **Vulnerability assessments** - to identify and address security issues in information systems and defend against malicious software (Vulnerability Management Standard), vulnerability assessments must be carried out in accordance with the NPCJ's Vulnerability Management Standard.

- Security awareness training - All NPCJ personnel and students must receive security awareness training as part of their induction and as part of a yearly security training program. Additional training is required for employees who are:
 - Those who are directly involved in the handling of security incidents, such as IT and security personnel, must ensure that their duties and responsibilities are clear and understood.
 - Assigned privileged access rights to information systems or retain access to NPCJ data designated as "Highly Sensitive," "Sensitive," "Private," or "Public" according to the NPCJ Data Classification Standard.

8.1.2 Security Incident Detection & Reporting

All NPCJ employees must be aware of what constitutes a possible information security incident, how to report one, and what measures they should and should not take.

All members of the NPCJ must participate in the handling of security issues. All issues must be handled in accordance with the security incident management policies/protocols in place at the local (Faculty, Divisions) and enterprise (NPCJ IT) levels.

Example Security Incidents

- A virus on a computer (major outbreak).
- Unauthorized disclosure of sensitive information (e.g., Personal Identifiable Information (PII) of staff and students).
- Lost or stolen identification devices and/or removable media.
- Passwords are either stolen or leaked.
- Unauthorized access to the NPCJ's computer system or physical location.
- Unauthorized personnel in a restricted NPCJ facility, such as a faculty computer laboratory or the NPCJ IT computer room. Where technically possible the detection and reporting of potential information security incidents must be automated. Examples of automated detection and reporting include alerts generated by:
 - Anti-virus.

- Firewalls, IDS/IPS.
 - SIEM.
 - Protective and detective security services.
- a. A threat management process must exist to triage and treat potential incidents that are detected and ensure that appropriate action is taken quickly and effectively without adverse impact to NPCJ business services.
- b. NPCJ must ensure that business partners and third parties maintaining direct or indirect access to NPCJ data, information, and systems are contractually obliged to notify NPCJ in cases of security incidents affecting NPCJ.

8.1.3 Security Incident Analysis & Escalation

- 8.1.3.1. Security issues must be documented, reviewed, remedied, and escalated in accordance with local (Faculty, Divisions) and enterprise (NPCJ IT) security incident plans and processes. The process must be able to manage extremely sensitive incidents with low documentation requirements.
- 8.1.3.2. On receipt, all real or suspected information security incidents must be classified according to the following criteria:
 - a. Defined incident types, identification of potentially affected parties (internal and external, such as NPCJ workers and business partners/third parties).
 - b. The influence on NPCJ's IT and network infrastructure. Local (Faculty, Divisions) and Enterprise (NPCJ IT) teams must coordinate with the Customer Technology Services and Security Operations Teams to assess the nature and criticality of the incident as per the Security Incident Handling Plan / Process, see Control 1.4.1), or close the incident with justification.
- 8.1.3.3. The Security Incident Management Team may include personnel from NPCJ IT, Faculties, Divisions, other NPCJ specialist functions such as HR, Legal, Media and external incident management Subject Matter Experts.
- 8.1.3.4. During the assessment phase the incident may be escalated to a “disaster”, triggering the ITSS_16 IT Recovery Standard and the respective IT Recovery

Plan.

8.1.3.5.A documented escalation and communication process must be in place to ensure appropriate stakeholders (e.g. senior management, ISSG, Information Security Task Force, HR, Legal and Media) are alerted during a security incident. The incident may need to be disclosed to:

- a. NPCJ Students and/or academic staff if the information security incident involves material subject to Privacy laws and regulations, such as Personally Identifiable Information (PII) and credit/debit card details.
- b. Relevant state and commonwealth law enforcement agencies if the incident involves a breach of regulatory obligations.

8.1.3.6. Legal advice must be sought from the JCF Legal team before informing regulatory and or law enforcement agencies. NPCJ Student Services must be engaged if the incident involves a student or the broader student community.

8.1.4 Security Incident Handling

8.1.4.1. A documented Security Incident Response Process/Plan (according to the incident's type and nature) must be implemented which provides an analytical set of operational instructions in order to assist NPCJ's Security Incident Management team to:

- a. Respond in a correct manner to detected security incidents including their containment and eradication.
- b. Perform quick and efficient recovery from security incidents returning to either a prior state, or a more secure state.
- c. Preserve the integrity of the relevant data and evidence for potential litigation (if applicable).
- d. Interact with the media, including social media, to manage external visibility and discussion around the incident.

8.1.5 Post Security Incident Review

8.1.5.1. A post security incident review is required for severity one information security incidents to identify the root cause of the issue, and what improvements must be made

to prevent re- occurrence. After investigation, incidents must be re-classified (where appropriate) according to the actual impact. Incidents that are judged to be ‘false alarms’ or ‘no impact’ must be recorded as such. This review must be completed within two weeks of the security incident resolution.

8.1.5.2. A record of all suspected and actual information security incidents must be maintained, including all actions taken in investigating, assessing and responding to information security incidents.

8.1.5.3. The record of suspected and actual information security incidents must be regularly reviewed as part of the information security management lifecycle to identify changes in the threat environment that call for adjustments to the Information Security Risk Assessment Process (Information Security Risk & Compliance Management), IT Security Policy, and/or Security Standards and Procedures.

8.2 Vulnerability Management

8.2.1. Vulnerability and security patch management

8.2.1.1. All systems must have standard security configurations in accordance with industry best practices and vendor guidelines.

8.2.1.2. A defined and approved methodology for patch and vulnerability management (assessment and remediation) is required.

8.2.1.3. The procedure must meet the following criteria.

- a. Assess and justify systems that are relevant to the process in terms of risk, using the asset inventory as a guide.
- b. Assess the operational risk posed by disclosed vulnerabilities and prioritize repair steps to mitigate the risk.
- c. Define the roles and responsibilities for patch/vulnerability management on a technical level. These roles define who is in charge of:

I. **Vulnerability monitoring** - individuals who get vendor and other security advisory group warning notifications.

II. **Vulnerability risk assessment** - those who assess the

environmental effect and set priorities.

III. **Patch application authorization** - for change control.

IV. Those who test and apply patches are known as patch verification.

V. **Patch management** - those in charge of tracking patch distribution across NPCJ's whole environment for all production systems.

d. Responsibilities for coordination: how the vulnerability notification and patch application are communicated across the various entities in charge of patch distribution.

e. Include a sub-process for tracking vendor announcements about technology platform end-of-life (software and hardware).

8.2.1.4. It is the responsibility of the third-party system owners or service providers to ensure that NPCJ information systems hosted within their infrastructure are fixed and are not vulnerable to known vulnerabilities.

8.2.1.5. Vendors' and security advisory groups' technical weaknesses must be addressed as soon as possible.

8.2.1.6. Patches are applied to the production environment in a timely way to ensure that it is running at peak efficiency.

8.2.1.7. When patches aren't easily available or deployment has an unacceptably negative impact on the college, the NPCJ IT Team should consider the following risk mitigation controls:

- Filtering on the network
- Tighter surveillance.
- Communication and awareness training
- Patching from afar.
- Turning off impacted services and functionality for the time being.

- 8.2.1.8. All patches must pass Security Acceptance Testing (SAT) and User Acceptance Testing (UAT) to verify that they do not compromise operational security or have a negative impact on the production environment.
- 8.2.1.9. For required modifications to the operating environment, the Change Management Process is used.
- 8.2.1.10. The "Security Incident Management Process" must be activated in order to comprehend the risk and respond correctly to vendor Zero-Day vulnerabilities.

8.2.2 Ongoing assessment to identify vulnerabilities

- 8.2.2.1. Specific security testing activities must be conducted to identify vulnerabilities in IT infrastructure and services on an ongoing basis. These include:
 - a. **Vulnerability Scanning** – To baseline the vulnerability posture, validate the patching process by identifying un-patched systems.
 - b. **Configuration Reviews** – Automated validation of approved security baseline configurations for application, server O/S, network and end user systems.
 - c. **Invalid Change Validation** – Leverage the configuration review process to confirm only approved configuration changes were actioned.
 - d. **Penetration Tests** – To test the effectiveness of the security controls implemented or to validate an identified weakness in a control that has been identified during the design review or product evaluation phase. The following criteria must be considered when establishing the need for a penetration test:
 - Governmental regulations.
 - System kind (internal vs. external).
- 8.2.2.2. Sorting the data (Data Classification Standard).

Security testing activities must be conducted as follows:

- Testing Requirements must be met before a system or application is put into

production, and they must be met dynamically during the life of the system or application.

- Dynamically for the life of the system or application
- As part of the project scope will be determined.
- Vulnerabilities discovered during security testing should be prioritized for remedy based on risk (highest severity first) and communicated to the business owner, with assistance if needed.

8.2.3 Monitoring the effectiveness of operational security measures

A key objective of threat and vulnerability management is to understand the changing nature of the threat environment, and to re-assess the effectiveness of information security controls in light of changing threats.

External threat intelligence can be obtained from a number of organisations, for example CISA, JaCIRT and global sources from open-source threat intelligence. Intelligence must be considered in the context of NPCJ IT services and used in assessing the adequacy and effectiveness of the security controls in operation, and in identifying new information security control requirements.

8.3 Anti-Virus and protection from malicious code or network traffic

NPCJ I.T implements systems to protect against malicious and mobile code to minimise the potential for the introduction of malicious software into the environment. All technology platforms prone to viruses must be monitored for potential malicious software activity using anti-Virus software. This allows malicious software to be identified, isolated, and removed using anti-Virus application controls.

8.3.1. NPCJ must deploy adequate protective information security controls to stop unauthorised code executing on IT assets, or detect signs of attack or that a machine may be infected or otherwise compromised. This includes:

- Anti-Virus signatures and engines are automatically checked for available

updates from the anti-Virus supplier at least once every 24 hours, or as advised and agreed with the vendor.

- Anti-Virus signatures are automatically deployed via a central service throughout NPCJ's environment within 24 hours of receiving the update from the supplier.
- Restrictions on mobile code, for example Java, may be restricted in standard IT equipment configuration. Users of this equipment are aware they must not attempt to circumvent these restrictions.
- All email and Internet web browsing traffic, both inbound and outbound is checked for the presence of malicious code. If malicious code is detected within emails, the message or web session shall be quarantined and IT notified to conduct an investigation.
- Intrusion Detection and Prevention Systems (IDS/IPS) are deployed to detect and prevent malicious network traffic (ITSS_15 Network Security Standard).

8.3.1.1. Anti-Virus and malicious code detection techniques must include defence and in-depth principles where possible.

8.3.1.2. Only approved (Faculty, Research, ACP approved or JCF approved) software with supporting legitimate business justification must be used on NPCJ information systems.

8.3.2. Verifying the integrity of key security controls

8.3.2.1. For key security controls, such as network and infrastructure security devices, it must be possible to verify the integrity of source code, executables and configuration, in case they have been accidentally or maliciously modified. This must be achieved by:

8.3.2.2. Deployment of integrity checking controls that regularly check integrity and alert on unexpected changes encountered.

8.3.2.3. Comparison of running configuration to a 'known good' configuration stored in a secure location with high-integrity.

8.3.2.4. Monitoring vulnerability management within third-parties

NPCJ must seek ongoing assurance from retained third-parties who maintain, store NPCJ information or connect directly to the NPCJ network. Assurance must be sought to ensure that third parties are managing vulnerabilities in accordance with NPCJ ITSS_20 Third Party Risk Management Standard. Implementation of Data Masking

8.4 Cryptography

As a means of protecting NPCJ sensitive information, cryptographic technology must be employed. NPCJ uses cryptographic methods to reduce the hazards associated with:

- Transmission and storage of NPCJ sensitive data from an NPCJ network to a site with lower security (e.g., the internet) or where a greater level of protection is necessary.
- Detection of unauthorized data alteration.
- Checking the transaction's legitimacy

8.4.1 The strength of the chosen cryptographic mechanisms must meet the required level of security for the information type, which is dependent on the type of cryptographic algorithm, the size, and the life cycle of the keys. (see Control 1.5.1).

8.4.2 All cryptographic solutions for data encryption and hashing chosen by NPCJ's IT staff must be internationally recognized and subject to public examination and verification of effectiveness.

8.4.1 Cryptographic Keys Management

For each solution that uses cryptography, a documented cryptographic key management plan must be designed and followed to ensure that cryptographic keys are managed safely. Employees of the NPCJ must have complete control over the entire process, from key issues through disposal. The procedure must encompass the whole cryptographic key life cycle:

- a. Generation – According to the Data Classification Standard, the cryptosystem's keys must be constructed in such a way that the desired security criteria (length, randomness) are met. The encryption keys used in test settings must differ from those used in production environments.
 - b. Storage – The storage of encryption keys must be done using techniques and procedures that ensure a level of protection at least equal to the level of security offered by the keys. Encryption technologies must be used to protect the encryption keys in electronic form, and the necessity for tamper-proof devices must be considered.
 - c. Renewal, Revocation & Disposal – The cryptosystem's keys must have an expiration date that is determined by the length, use, and confidentiality of the information they protect. All keys must be replaced before they expire, and the old keys must be destroyed in a secure manner.
- 8.4.2 The development, maintenance, and distribution of cryptographic key management processes are the responsibility of IT teams (NPCJ IT, Faculty, or School).
- 8.4.3 The default keys must never be utilized when using hardware encryption devices, including those used in testing environments. All equipment must be tamper-proof and well-protected physically, and permission to use them must be limited and always granted.
- 8.4.4 When hardware encryption devices are employed, including those used in testing environments, the default keys must never be used. All devices must be tamper-proof and well physically protected, while authorization for their use must be limited and always approved.

- 8.4.5 To avoid circumstances when encryption keys are lost and information cannot be decrypted, key owners must have access to cryptographic keys.
- 8.4.6 Access to secret or private keys must be strictly controlled in proportion to the level of security provided by the keys. Only authorized personnel should have access to the keys, which should be reviewed on a regular basis in compliance with the policy. ITSS_05 User Access Management Standard.
- 8.4.7 Segregation of Duties (SoDs) must be evaluated on a risk basis and implemented if feasible to reduce the possibility of a single individual gaining access to the entire cryptosystem, hence preventing malicious or inadvertent action.

8.4.2 Data Masking

Data masking applies to all NPCJ IT assets utilized in non-production environments for development, testing, or any other business activity. The following are examples of IT assets found in development and testing environments:

- NPCJ databases and servers
- Software, repositories, and data formats for development.
- File servers, office papers, spreadsheets, and messaging systems are all used in the workplace.
- portable hard drives, USB storage devices, and CD/DVDs are examples of removable storage devices.
- Unless there is a clear business requirement, NPCJ's sensitive data (in hard copy and electronic form) must be sanitized (i.e., personal context removed).

8.4.3 Implementation of Data Masking

NPCJ's IT Teams are responsible for the development, maintenance and distribution of masking guidelines and/or manuals.

- 8.4.3.1. Access to data masking tools and algorithms must be only provided to authorized personnel and reviewed periodically in accordance with the ITSS_05 User Access Management Standard.

- 8.4.3.2. NPCJ's IT Teams review the effectiveness and coverage of data masking implementations to ensure that data is masked in accordance with current and future business requirements.

8.4.4 Cryptographic and Masking Algorithms

To ensure that NPCJ's cryptography and masking practices are successful and not vulnerable to developing security risks, emerging cryptanalysis techniques, and/or cryptographic attacks, a Secure Algorithm List ("SAL") must be prepared and evaluated on a regular basis by appropriate IT Teams.

- 8.4.4.1. It is completely forbidden to use any algorithm other than those given in the SAL. The NPCJ's IT Change Management Process must be followed for any changes to the SAL.
- 8.4.4.2. A reversible data masking scheme is not allowed. NPCJ data methods must not be based on the original data (i.e., random generation) in order to assure that the original data cannot be reengineered.

8.5 User Controls

8.5.1 Access Control

- 8.5.1.1. On a per service basis and where practical, access to NPCJ information systems must be controlled by a centralised Authentication, Authorisation and Accounting system, (i.e. TACACS for network infrastructure or Active Directory windows domains).
- 8.5.1.2. Locally authenticated accounts are not permitted unless a valid academic, business or technical justification has been assessed and approved via the risk management process.
- 8.5.1.3. In line with this standard, access control requirements process and procedure must be developed to manage locally authenticated accounts.

8.5.2 General Access Provisioning and De-provisioning

- 8.5.2.1. All accounts must be associated with an owner i.e. one to one relationship and where possible assign to a group.

- 8.5.2.2. Access requests are approved by an appropriate authority (individual's manager) prior to implementation by the IT systems and application administrators.
- 8.5.2.3. Where possible, the following access control models must be considered and implemented for user authentication. For example: Role Based Access Control (RBAC) to allow NPCJ users to access information systems based on their role (e.g., prospect, student, alumni, academic staff) inheriting a pre-defined set of access rights.
- 8.5.2.4. Account and relative access rights must be removed or disabled when a user no longer needs access due to changing roles or leaving NPCJ.
- 8.5.2.5. Accounts for NPCJ contractors must always have an expiration date aligned with the contract period.
- 8.5.2.6. In case of an emergency (i.e. third party vendor requires access during a severity 1 situation) access requests are approved and documented retrospectively.
- 8.5.2.7. For applicable systems, owners or delegates must perform annual account revalidation to validate continued business need with the authorising authority. Accounts assigned to individuals in perpetuity such as "alumni" are exempt from annual revalidation.
- 8.5.2.8. The authenticating systems (i.e. TACACS, Active Directory) should reflect the current list of approved individuals.

8.5.3 Generic Accounts

- 8.5.3.1. Shared or generic accounts are not permitted unless a valid academic or business, justification has been assessed and approved via the risk management process.
- 8.5.3.2. For shared or generic accounts a process must be deployed and documented to detail purpose, ownership, accountability and security:
 - a. A responsible focal point is assigned to manage the account.
 - b. Purpose of account use, such as, short course accessing system for a specific time.
 - c. Names and contact details of individuals using the account.
 - d. Duration of account use i.e. temporary or permanent.

- e. Account passwords are reset when any individual no longer has a valid need to use the account.
- f. Business or academic need of the account and associated individuals must be revalidated annually.

8.5.4 Remote User Access

- 8.5.4.1. All remote access requests used to connect to NPCJ's information systems must be approved by an appropriate authority (e.g., individual's manager). Remote access to NPCJ's information systems must be strictly controlled and implemented according to the Network Security Standard. Remote access is subject to the following restrictions:
- 8.5.4.2. Users are securely authenticated (via a username/password pair or where applicable using an additional, second authentication method such as PIN or smart card) prior to the establishment of a remote connection.
- 8.5.4.3. "Highly Sensitive", "Sensitive", and "Private" data must be encrypted when the data is transferred through public networks (i.e., Internet).
- 8.5.4.4. Remote access accounts with privileged rights for administrative use must be limited to authorised personnel and strictly controlled via:
- 8.5.4.5. Two-factor authentication i.e. smart card, soft token or PIN.
- 8.5.4.6. Regular monitoring of event logs.
- 8.5.4.7. Periodic reviews, at least annually, of access rights to verify the ongoing appropriateness of access rights.
- 8.5.4.8. Users must not attempt to circumvent remote access (VPN) security controls. Any deviations must be addressed from a risk perspective and approved by the remote access and end point system business owner.

8.5.5 Federated User Access

Federated access to allow NPCJ to reuse identities and simplify user account management.

- 8.5.5.1. Trusted third parties must be selected as federated partners.

- 8.5.5.2. NPCJ must retain control over the access rules for granting access to the sensitive information it owns. Please refer to the “Federation Governance Document” for direction.

8.5.6 User Accountability

All NPCJ users are personally responsible for the use of their account and must:

- Select and use strong passwords.
- Change their password if they know or suspect that their account has been compromised.
- Keep passwords secure, and not reveal them under any circumstances.
- Not attempt to use any account other than their own, unless for legitimate support or security incident purposes.
- Not share their user account with other individuals.

8.5.7 Account Management

- 8.5.7.1. NPCJ staff and contractors are assigned with a single user identifier to be used when accessing NPCJ’s information systems (e.g., default z-ID).
- 8.5.7.2. A standard Naming Convention scheme is followed when creating accounts in order to facilitate the accountability of user actions.
- 8.5.7.3. User account management controls must be established to lock user accounts after a defined number of failed authentication attempts:

Account Management Characteristics	Account Management Policy
Account lockout threshold	Ten (10) consecutive invalid password attempts
Account lockout duration	Thirty (30) minutes
Account inactivity lockout	<u>Note: This must be determined according to the account type (e.g., student, alumni, staff & academic staff) and detailed within the IDAM process documentation.</u>
Maximum user screen lock out inactivity	The maximum user inactivity timeout, requiring password re-entry, thirty(30) minutes

**The above account management policy requirements apply to all NPCJ staff and students as well as privileged/administrator users.*

8.5.8 Password management

8.5.8.1. Passwords are mandatory for all user accounts on all networked and standalone information systems including operating systems, applications, databases, end user computing hardware and mobile devices (notebooks, tablets etc):

Password Management Characteristics	Password Policy
<u>Minimum length</u> ensuring passwords are not easily derived.	Minimum Eight (8) and a recommended Fourteen (14) characters or more and;
<u>Complexity</u> ensuring passwords are not easily derived.	A Password must comply with any Three (3) of the following: • <u>Minimum</u> One (1) Alpha (upper) • <u>Minimum</u> One (1) Alpha (lower) • <u>Minimum</u> One (1) Numeric
	characters • <u>Minimum</u> One (1) Special character (e.g., %, #) And; • NOT contain <u>Account Name</u>, <u>First name</u>, <u>Surname</u> or <u>Full Name</u>.
<u>Maximum password age</u> limiting the utility of a breached password.	One hundred and eighty (180) days
<u>Minimum password age</u> to prevent users from reverting to their old password immediately after an enforced password change.	Five (5) days
<u>Password history</u> to prevent users from reusing their twelve (12) previous passwords.	Twelve (12) passwords

**The above password policy requirements apply to all NPCJ staff and students as well as privileged / administrator.*

- 8.5.8.2. Where technically feasible, users must change their password at first login.
- 8.5.8.3. Passwords must not be displayed “in the clear” on input and fixed screens, hard copy reports or electronic files.
- 8.5.8.4. Default passwords shipped with any information system must be immediately changed upon installation of the software.
- 8.5.8.5. Passwords must not be based on anything that can be easily guessed or obtained using collateral information. The following must be avoided:
- 8.5.8.6. Passwords related to Names, Date of Birth, Telephone Numbers, Family information, etc.
- 8.5.8.7. Common words found in dictionaries.
- 8.5.8.8. Common words or terms; relating to NPCJ.

8.5.9 Privileged User Access Management

- 8.5.9.1. For the purpose of this Standard the following definitions have been used for IT specific user accounts:

IT User Accounts	Description
Privileged accounts	A personalised account that has elevated access rights to information systems to perform administrative activities
Functional accounts	Default accounts provided from software vendors such as Administrator, Guest, Root, DBA, Built In, Hardcoded
System accounts	Accounts used for system to system communication such as Oracle Listener, Nagios, TACACS pre-shared keys, IPSEC pre-shared keys, SNMP strings.
Service accounts	Group mailbox accounts. Approved shared or generic accounts.

8.5.9.2. Privileged accounts

- 8.5.9.2.1. Privileged access enables certain users to perform administrative and maintenance tasks on NPCJ information systems. Privileged access to an information system must be provided to users only if they have a need for such access as part of their job responsibilities and NPCJ business needs.

- 8.5.9.2.2. Every privileged account must have a one-to-one relationship with an individual.
- 8.5.9.2.3. Privileged access rights must be controlled via two-factor authentication (i.e., smart card, soft token or PIN).
- 8.5.9.2.4. In the event a staff member, who has privileged access, has resigned or is terminated the account must be disabled within a reasonable timeframe commensurate with the level of perceived risk and documented within ID Access Management (IDAM) process and procedure.

8.5.10 Functional accounts

- 8.5.10.1. The ownership and business purpose of functional accounts must be documented and maintained.
- 8.5.10.2. Where technically possible, functional account privileges (root) must be substituted i.e. assigned to an individual (Linux Sudo rights). Where not, functional accounts (hardcoded) must be afforded the same controls as generic accounts.

8.5.11 System accounts

- 8.5.11.1. The ownership and technical purpose of system accounts must be documented and maintained and only made available to individuals with a valid technical need.
- 8.5.11.2. Management of system account “passwords” or “pre shared keys” used to authenticate or encrypted inter system communication must be considered from a risk perspective. Appropriate controls must be selected to mitigate potential the breach of access.

8.5.12 General

- 8.5.12.1. Consideration from a risk perspective to segregation of duties must be afforded and documented within the system design documentation.
- 8.5.12.2. Access controls are established such that system users/administrators are not able to modify critical system data (for example event logs).

8.6 Web Application Security

8.6.1 Security principles for web applications

8.6.1.1. To achieve ‘safe by design’ for Web applications, specific security controls must be addressed at the Design, Build and Test Phases of NPCJ Web Application development processes.

8.6.2. Design - Segregation of web application function to create defence in depth

An important requirement that must be addressed to secure information within services connected to un-trusted networks is to apply a “defence in depth” strategy. Defence in depth can be achieved through the implementation of security zones of different trust. This ensures that important information is never directly accessible from zones where there is either no or minimal trust, for example the Internet or other external network(s) outside NPCJ’s control.

Implementation of this requirement means that security mechanisms are required to control all communications with un-trusted networks so that any single vulnerability identified in a security control / zone does not expose important information – multiple vulnerabilities in different controls / zones would be required before this information is exposed.

8.6.2.1. Solutions architecture must be separated into security zones. The number and classification of zones must be defined based on the classification of information stored within the security zone, and the source types of network that will access this information.

8.6.3. Logical Network Security Zone Model (ITSS_15 Network Security Standard extract)

In line with the new Security Architecture model, NPCJ networks should be viewed as security zones, each zone (reference new security architecture) is defined as having criteria which describes the type of services that can be deployed for processing or storage and therefore the strength of security control afforded.

To understand which zone is appropriate for service within the new model the appropriate security questionnaire must be completed which takes into consideration data classification, threats and vulnerabilities.

8.6.4. Security Zones Characteristics

Security Zone	Zone Characteristics
Internet	External (Internet) networks or other networks without a trust relationship.
External Trusted	External Cloud or Managed Service provider.
Secure DMZ Semi-Trusted	Devices such as security appliances (Firewalls, IDS/IPS, SIEM, Content Filters), RAS and Web Servers.
Old Architecture Semi Trusted	Legacy network architecture hosting systems outside the new security architecture.
New Security Architecture (low, medium) trusted	An internal zone which can host highly sensitive information for systems of a low or medium risk nature.
New Security Architecture (high) highly trusted	An internal zone which can host highly sensitive information for systems of a high risk nature.

- 8.6.4.1. The standard is intended to be flexible and accommodate different solutions designs and architecture. The solutions delivery team must consider the number and type of zones required by understanding:

- a. The purpose of the zone, for example to facilitate and proxy communications, or to provide management access to maintain the service.
- b. The classification of information that is stored in persistent storage within the zone.
- c. Whether the sources of requests that are made to that zone are under direct or indirect control of NPCJ, for example the Internet is not under NPCJ control.

8.6.4.2. This mandates that the design of web applications will implement controls to adequately protect information from threats by:

- a. Segregating web application functionality into well-defined security zones and then applying rules for the storage and processing of classified information within these zones.
- b. Terminating traffic between trusted and un-trusted networks within a de-militarized zone (DMZs).
- c. Preventing direct access to sensitive information from un-trusted security zones and preventing direct connections across more than one consecutive security zone.
- d. All sensitive web applications must be accessible via secure network protocols such as HTTPs.

8.6.5 Build - development of web applications

The Open Web Application Security Project (OWASP) is a source of industry good practice for the design, development, testing and deployment of web applications. In particular, the OWASP Top 10 considers the top 10 most critical security risks for web applications.

- <http://www.owasp.org>

8.6.5.1. The OWASP Top 10 must be considered during any design, development or change activity to web applications, and compliance or otherwise must be documented as part of the solution design.

- 8.6.5.2. The source code for all web applications must be checked during development for commonly known vulnerabilities, for example by using either static or dynamic source code analysis tools within the software development lifecycle.

8.6.6 Test - Security testing of web applications

- 8.6.6.1. Penetration testing must be considered on a risk basis (including vulnerability assessment) on newly-developed applications prior to their migration to production.
- 8.6.6.2. The need to perform future penetration testing must be considered on a risk basis.
- 8.6.6.3. Penetration testing activities must include attempts to disrupt the logic of the applications to identify whether the application's business logic has security flaws. These flaws may allow a user to perform an operation that is not allowed by the business, or invoke particular operations out of sequence to compromise the system. Attacks on the business logic of an application are specific to the application being tested, and specific test cases must be developed for each application.
- 8.6.6.4. Once vulnerabilities are remediated, retesting must be performed to validate.
- 8.6.6.5. Formal source code reviews must be performed and signed off. A formal source code review process must be established for the timely identification, escalation and remediation of source code vulnerabilities.

8.7 Physical Security

Facility design and equipment security

8.7.1 Cabling Security

- 8.7.1.1. In line with industry electrical / cabling standards precautions must be taken to mitigate the risk of unauthorised / malicious data interception and accidental / malicious damage to ICT installations.
- 8.7.1.2. Electric cabling is physically separated from data cabling to prevent interference and reduce risk of injury and damage to equipment.
- 8.7.1.3. All power and telecommunications lines into information processing facilities are underground, or subject to adequate alternative protection.

- 8.7.1.4. All cabling and networking equipment is clearly labelled using a documented convention to minimise handling errors.
- 8.7.1.5. Any communications or networking equipment (routers, switches, hubs, and patch panels) is protected against unauthorised physical access by either placing it within a secured data centre or a locked cabinet or room.

8.7.2 General workplace security

- 8.7.2.1. Removal of equipment and security of off-site equipment
- 8.7.2.2. Employees and contractors must not remove property (except mobile devices) from NPCJ premises without prior authorisation.
- 8.7.2.3. An inventory of all IT assets must be maintained, which lists equipment that has been removed from NPCJ premises.
- 8.7.2.4. NPCJ employees that travel with a laptop or other equipment with “Sensitive” information, including portable hard drives, must be cautious and keep the items secure. Specific security mechanisms (strong authentication and encryption) should be considered for the devices according to the classification of the data stored on each device (Data Classification Standard).
- 8.7.2.5. All storage media taken off site by service providers (such as faulty disk drives and tapes) requires specific physical management and destruction procedures, as described in the Data Classification Standard.

8.7.3 Controlling access to secure areas & buildings (equipment room)

- 8.7.3.1. All employees, contractors, vendors, and visitors must be authorised by the equivalent NPCJ Manager / Commanding Officer, ACP Training or an appropriate approval authority, for physical entry into secure NPCJ facilities.
- 8.7.3.2. Badges must be carried by employees, internal contractors and displayed by third party contractors or visitors. Badges must be designed to clearly distinguish visitors and employees. Temporary badges must expire after a pre-determined period of time.
- 8.7.3.3. All employees, contractors, vendors and visitors must report any lost identification badges immediately to the department or faculty and inform NPCJ Guard Room (Basic Area).

- 8.7.3.4. Employees must notify NPCJ Campus Security or the NPCJ Guard Room of any suspicious personnel within NPCJ secure areas.
- 8.7.3.5. Physical access rights must be removed or disabled as soon as possible when an employee, contractor or visitor no longer needs access due to changing roles or leaving NPCJ.
- 8.7.3.6. Physical access rights must be regularly reviewed by the NPCJ Manager or delegate who initially approved access to NPCJ premises. This review must be conducted annually.

8.7.4 Controlling incoming and outgoing objects

- 8.7.4.1. When receiving incoming objects, caution should be taken, anything suspicious should be reported to management for direction before handing the object further.
- 8.7.4.2. Equipment, except for portable devices, must not be removed from NPCJ premises unless authorisation has been obtained in writing (email) from a NPCJ Department or Faculty Manager or delegate.

8.7.5 Server Room Security

- 8.7.5.1. The controls in this section of the Standard apply to all NPCJ Data Centres including decentralised computer rooms located in Divisions and Faculties.

8.7.5.1 Server Room environmental control

- 8.7.5.2. All data centre facilities are protected against fire, water damage, vandalism, and other threats known or likely to occur at their geographical locations.
- 8.7.5.3. Walls surrounding data centres are non-combustible and resistant to fire. All openings to these walls (e.g., doors, ventilation ducts, etc.) must be self-closing and resistant to fire. All IT equipment in NPCJ data centres operate in a climate-controlled environment at all times. Temperature and humidity sensors are installed to detect any environmental change and trigger an alarm.
- 8.7.5.4. All necessary measures must be in place to ensure that if a fire breaks out, it can be quickly controlled and suppressed. Specific measures must be in place such as smoke detectors, automated fire suppression systems as well as fire-extinguishers.

- 8.7.5.5. All data centre personnel are trained in the use of portable fire extinguishers.
- 8.7.5.6. Data centres must be equipped with environmental controls to manage the environment such as water, power or temperature.
- 8.7.5.7. Uninterruptible Power Supplies (UPS) are used to provide short-term power when the power fails and to protect information systems from voltage spikes and reductions.
- 8.7.5.8. Where appropriate (risk based approach), redundant electrical power supply (e.g., backup power generator) must be in place to support information systems in the event of a prolonged power outage.

8.7.6 Controlling access to Server Room

- 8.7.6.1. Physical access to the server room is controlled through physical access card control system. In case where a physical access control system cannot be installed to decentralised computer rooms, other authentication methods must be in place such as pad locks.
- 8.7.6.2. Physical access to the server room is limited to employees with a valid business reason. Access must be revoked immediately once it's no longer needed. Additional access should be revalidated as a secondary control.
- 8.7.6.3. Access logs produced by physical access card control systems are retained for one (1) year. Access to the system storing the logs is strictly controlled and limited to authorised individuals.
- 8.7.6.4. All visitors must sign in when entering data centres. The name, organisation being represented, date, time of entry and departure, and person being visited must be logged. Visitor log information must be retained for a minimum of two (2) years.
- 8.7.6.5. Where appropriate (risk based approach), server room entry points are monitored via a Closed-Circuit Television (CCTV) system on a 24/7 basis. All video surveillance data must be protected from unauthorised disclosure and modification and maintained for at least ninety (90) days.
- 8.7.6.6. Server room are equipped with doors that automatically close immediately after they have been opened, and that set off an audible alarm when they have been kept open beyond a pre-determined period of time.

- 8.7.6.7. Decentralised computer rooms containing network, wiring or communications equipment (e.g., wiring closets, etc.) are locked at all times with access restricted to authorised personnel only. Signs are not to be posted on wiring closets, telephone rooms, data centre facilities or other equipment components that would attract the attention of unauthorised individuals.
- 8.7.6.8. NPCJ IT employees hosting visitors (e.g., IT vendors) must ensure that their visitors are escorted at all times when in the server room.

8.7.6.1 Equipment Maintenance

- 8.7.5.1. All equipment utilities (e.g. UPS, generator, fire suppression system) are monitored in accordance with manufacturer specification and correctly maintained. Procedures exist for NPCJ Facilities Management to test equipment at least once every six (6) months. The test results must be documented and communicated to the Security Operations Manager.
- 8.7.5.2. All regular maintenance activities are documented in the operational documentation of the Facilities Management Division. The documentation includes the frequency and details of routine maintenance that needs to be performed.
- 8.7.5.3. Facilities Management must make available to the Data Centre Manager the following:
- The maintenance schedule of equipment depicting the activities to be conducted and the contact details of the individuals (including third parties) who will be performing the maintenance work.
 - The maintenance reports describing the activities completed, any problems identified and the respective problem resolution activities.
- 8.7.5.4. Details of maintenance agreements such as start-date, end-date and vendor contact details must be kept in operational documentation maintained by Facilities Management.
- 8.7.5.5. Only authorised maintenance personnel are allowed to perform repairs. Data Centre Managers must grant access to the maintenance personnel outlined in the maintenance schedule.

8.8 Bring Your Own Device (BYOD)

8.8.1 NPCJ's Responsibilities (Standards)

- 8.8.1.1. NPCJ reserves the right to disconnect any device that places NPCJ ITC environment at risk.
- 8.8.1.2. IT support for BYOD devices is provided on a best efforts basis only. Device owners are encouraged to follow the controls detailed within this document.
- 8.8.1.3. NPCJ will monitor device usage in line NPCJ Acceptable Use, Privacy and other JCF Policies.

8.8.2. Bring Your Own Device - Smart Phone or Tablet Devices (Guidelines)

Remember your smartphone or tablet device is a computer, therefore best practises to protect your personal, NPCJ and business sensitive information should be employed.

- 8.8.2.1. Ensure operating system and installed “Apps” software, is up to date to protect against known vulnerabilities.
- 8.8.2.2. Configure a passcode to gain access to your device to protect against unauthorised access.
- 8.8.2.3. Install a secure safe or password manager to store your usernames, passwords and other confidential information.
- 8.8.2.4. Leverage device bio-metric access controls if available.
- 8.8.2.5. Set an idle timeout that will automatically lock the device when not in use. This also helps prevent unauthorised access.
- 8.8.2.6. Install industry standard security solution software, featuring anti-virus, firewall and threat intelligence capabilities.
- 8.8.2.7. Run regular virus scans and resolve issues.
- 8.8.2.8. Only obtain “Apps” from trusted sources such as “Apple iTunes Store” or “Google Play Store”. To prevent against malware that may be distributed via untrusted channels.
- 8.8.2.9. Do not “jailbreak” or “root” your device as it removes the manufacturer’s protection against malware.

- 8.8.2.10. Perform regular data backups to ensure your information is available, should your device be lost, stolen, broken or data corrupted.
- 8.8.2.11. Only store NPCJ sensitive information on your device if absolutely necessary, i.e. justified academic, research or business need. Ensure sensitive information is encrypted.
- 8.8.2.12. If you store sensitive information on your device ensure it is securely removed or transferred to a secure location when no longer required.
- 8.8.2.13. If you share your device with friends or family, restrict access to NPCJ sensitive information stored on your device.
- 8.8.2.14. Enrol your device in a “Find My Phone” service to locate and wipe your device if lost or stolen.
- 8.8.2.15. Record the details of your phone in case of theft. Every phone and cellular tablet has a unique International Mobile Station Equipment Identify (IMEI). Most phones allow you to find your IMEI by keying in *#06#. Knowing this number will help your provider stop your phone from being used if stolen.
- 8.8.2.16. Label your device with your name and phone number, so it can be returned if stolen or lost even if the battery is dead.
- 8.8.2.17. In the event a device containing NPCJ information is lost or stolen, report the incident to your local IT Support unit or the NPCJ IT Service Desk on 876-749-9399 or email it.npcj@jcf.gov.jm.
- 8.8.2.18. When you recycle your phone, make sure you delete all resident NPCJ information and reset the device to factory settings.
- 8.8.2.19. Employ reasonable physical security measures when traveling with your device or when at NPCJ

8.8.2 Bring Your Own Device - Notebook or Laptop Computers (Guidelines)

- 8.8.2.1. Ensure all operating system, firmware and application security patches have been applied, to protect against known vulnerabilities.
- 8.8.2.2. Configure your device with a strong password or phase phrase.
- 8.8.2.3. Install a secure safe or password manager to store your usernames,

passwords and other confidential information.

- 8.8.2.4. Leverage device bio-metric access controls if available.
- 8.8.2.5. Set an idle timeout that will automatically lock the device when not in use.
This also helps prevent unauthorised access.
- 8.8.2.6. Install industry standard security solution software, featuring anti-virus, firewall and threat intelligence capabilities.
- 8.8.2.7. Run regular virus scans and resolve issues.
- 8.8.2.8. Only obtain applications from trusted sources, to prevent against malware that may be distributed via untrusted channels.
- 8.8.2.9. Perform regular data backups to ensure your information is available, should your device be lost, stolen, broken or data corrupted.
- 8.8.2.10. Only store NPCJ sensitive information on your device if absolutely necessary, i.e. justified academic, research or business need. Ensure sensitive information is encrypted.
- 8.8.2.11. If you store sensitive information on your device ensure it is securely removed or transferred to a secure location when no longer required.
- 8.8.2.12. If you share your device with friends or family, restrict access to NPCJ sensitive information stored on your device.
- 8.8.2.13. Label your device with your name and phone number, so it can be returned if stolen or lost even if the battery is dead
- 8.8.2.14. In the event a device containing NPCJ information is lost or stolen, report the incident to your local IT Support unit or the NPCJ IT Service Desk on (876) 749 9399 or email it.npcj@jcf.gov.jm.
- 8.8.2.15. When you recycle your device, make sure you delete all resident NPCJ information.
- 8.8.2.16. Employ reasonable physical security measures when traveling with your device or when at NPCJ.

8.8.3 Portable Storage Devices and Cloud Storage Solutions

- 8.8.3.1. Perform an anti-virus scan of all portable (USB) media before executing files.

- 8.8.3.2. Only store NPCJ sensitive information on your device or in the cloud if absolutely necessary, i.e. justified academic, research or business need. Ensure sensitive information is encrypted.
- 8.8.3.3. If you store sensitive information on your device or in the cloud ensure it is securely removed or transferred to a secure location when no longer required.

8.8.4 Access to the Wi-Fi, Bluetooth and Wired networks

Standards

- 8.8.4.1. NPCJ allows owners of BYOD to connect to NPCJ's wireless network (npcj-wifi) to access NPCJ systems and the internet. The following controls are considered mandatory.
- 8.8.4.2. Access must be authenticated (WPA2/PSK) before connecting to NPCJ network.
- 8.8.4.3. The security logs created by the wireless must be managed according to the NPCJ Logging and Monitoring Standard.
- 8.8.4.4. Individuals must abide by the rules for use as described in the NPCJ IT Acceptable Use Standard at all times.

Guidelines

- 8.8.4.1. Only enable Bluetooth when required to mitigate the risk of malicious activity.
- 8.8.4.2. Avoid devices running versions of Bluetooth prior to V4, as these are more susceptible to vulnerability.

8.9 Network Security

8.9.1 Security Principles

NPCJ networks must be designed, implemented and managed using security best practices. The following are the best practice principles by which the NPCJ network architecture and design must align to:

- **Security by design** – Deploy infrastructure and services which can be secured

appropriately and accessed by authorised parties only. All infrastructure and devices must be secured in line with vendor best practices.

- **Defence in depth** – Implement multiple layers of security enforcement points / controls and never allow direct connectivity to internal (trusted) NPCJ networks from untrusted networks (e.g. Internet).
- **Least Privileged** – Users must never have administrative privileges by default, they must be escalated to the administrator by an appropriate method. Remote administrator access must require two factor authentication to access the administrative account. For remote access details see the ITSS_05 User Access Management Standard.
- **Highly available** – Perimeter infrastructure must be robust, reliable and resilient to failure to ensure external connectivity is maintained for business services. Consider using Distributed Denial of Service (DDoS) infrastructure and/or services.
- **Positive security model (default deny)** - Only required information and services are exposed to untrusted networks, explicit permit must be granted on a case by case basis. See firewall section for details.
- **Data protection** – Protect information and services using encryption or other secure channels to prevent session eavesdropping/hijacking and data loss when sensitive data is being sent via untrusted/public networks (refer to the NPCJ Data Classification Standard).
- **Trust / Zone Model** – deploy a security model which is based upon trust, data / service criticality and security zones. Inherent to this model is the idea of enforcement points segregating trust zones, and highly critical data contained within highly secure / trusted zones.
- **IPv6** – Network and security design (new and re-design) considerations must take into account IPv6 requirements (e.g. new devices must be IPv6 capable).
- **Cloud Environments** – For both internal and external cloud security controls, see the Cloud Security Standard.

8.9.2 Network Diagrams

8.9.2.1. Logical network diagrams must be created and maintained for NPCJ networks.

The format of these diagrams can be stored as hard copy (e.g. paper), soft copy (e.g. MS Visio diagram) or logical (e.g. dynamically created via network management applications). The information captured in these diagrams should consider the following environments and be able to aid support, design and implementation. System owners are at liberty to decide how best to achieve this requirement.

- Gateway and core network connectivity.
- Data Centre connectivity.
- Management network connectivity.
- Wireless network connectivity.
- WAN connectivity from the local distribution layer to the NPCJ core.
- Campus connectivity from the distribution layer to the NPCJ core.
- Faculty, Divisional access layer connectivity.
- Trust / Security zone boundaries and traffic flow.

8.9.2.2. For multiple sites or multiple devices with the same or similar design, a site/device template should be documented and referenced for each site or group of systems.

8.9.2.3. Network topology diagrams must be kept protected and access limited to authorised IT personnel only; as network topology diagrams typically contain private IP addressing and other sensitive information.

8.9.2.1 Logical Network Security Zone Model

In line with the new Security Architecture model, NPCJ networks should be viewed as security zones, each zone (reference new security architecture) is defined as having criteria which describes the type of services that can be deployed for processing or storage and therefore the strength of security control afforded.

To understand which zone is appropriate for service within the new model the appropriate security questionnaire must be completed which takes into consideration data classification, threats and vulnerabilities.

8.9.2.2 Security Zones Characteristics

Security Zone	Zone Characteristics
Internet	External (Internet) networks or other networks without a trust relationship.
External Trusted	External Cloud or Managed Service provider.
Secure DMZ Semi-Trust	Devices such as security appliances (Firewalls, IDS/IPS, SIEM, Content Filters), RAS and Web Servers.
Old Architecture Semi-Trust	Legacy network architecture hosting systems outside the new security architecture.
New Security Architecture (low, medium) trusted	An internal zone which can host highly sensitive information for systems of a low or medium risk nature.
New Security Architecture (high) highly trusted	An internal zone which can host highly sensitive information for systems of a high risk nature.

8.9.2.3 Traffic Flows between Security Zones

8.9.2.3.1. Information flow between different security zones must be via an appropriate enforcement point. The following security technologies can provide this functionality (NB: one or more of the following technologies can be used as an enforcement point):

- Firewalls to enforce the flow of information between zones based on port, protocol and/or application (next generation firewalls).
- Intrusion Detection/Prevention Systems to inspect traffic for malicious and anomalous activity.
- Proxy technology e.g. content filtering to monitor and control the use of specific services, for example email (SMTP) and web browsing (HTTP/S) traffic.
- Web Application Firewalls (WAF) to protect internet facing web applications.

8.9.3 Virtualisation

Modern network and infrastructure equipment supports virtualisation techniques making it possible for a single hardware platform to run a number of virtual instances hence reducing cost of ownership and improving implementation timeframes dramatically. Virtualisation is permitted when:

- 8.9.3.1. Security Zone and Traffic Flow requirements are adhered to.

8.9.3.2. All applicable ISMS key controls are implemented at Hypervisor and VM level just as they would for a physical deployment as outlined in the ISMS base document:

- Establishment of Services.
- Inventory Management.
- ID Management.
- Access Control.
- Key Management.
- Syslog Management.
- Backup Management.
- Patch Management.
- Vulnerability Scanning.
- Malware (AV) Management.
- IDS / IPS Management.
- Configuration Integrity Management.
- Unauthorised Change Management.
- Security Incident Management.
- Documentation Management (Policy, Process, Procedure).
- Risk Management.
- Disestablishment of Services.

8.9.4 Firewalls

8.9.4.1. Firewalls must be:

- Managed using a central management console with change control tracking capability.
- Deployed in a high availability / fail-over configuration for high availability networks.

8.9.4.2. Firewalls must perform the following functions:

- All incoming and outgoing data packets are filtered through stateful inspection.

- Filter incoming and outgoing data packets through configurable rules.
 - Inspect every packet and blocks on both policy and protocol violations.
- 8.9.4.3. Use due diligence and rule validation when creating or modifying firewall rules to ensure changes do not negatively impact the security posture of the environment.
- 8.9.4.4. Firewall rules must:
 - Specify the permitted service, service port number/protocol, source and destination address relevant to the business, security or management need of the traffic flow.
 - Each firewall rule set (management, security & operational) that permits traffic must have a specific business requirement and associated owner documented to avoid miss configuration and aid revalidation.
 - Be formally reviewed at a frequency decided and justified by the owner. The review must be conducted to validate the rule base for appropriateness and accuracy.
 - Be reviewed to highlight used and unused rules.
 - Revalidate management, security and operational rules bases with owners to confirm continued need and appropriateness of rule.
- 8.9.4.5. Any discrepancies identified must be recorded and resolved accordingly via the Change Management Process.

8.9.5 Intrusion Prevention

- 8.9.5.1. Intrusion prevention system capability must be deployed to detect and block malicious and suspicious traffic. If intrusion prevention is not available then intrusion detection must be used and integrated into the incident response process. Note: Care should be taken to arrive at a reasonable baseline and not act on false positive events that may cause an unnecessary outage.
- 8.9.5.2. Intrusion prevention systems should be deployed in monitoring / learning mode for a predefined period, or when NPCJ is confident it can manage the level of detected false positives. Once learning mode has been completed the intrusion prevention systems must be modified to operate in blocking mode in order to enforce traffic

(both ingress and egress) passing between internal and external facing security zones.

8.9.5.3. Intrusion prevention system policy must be configured to:

- Use specific signature sets appropriate for the networks it is protecting.
- Detect traffic anomalies.
- Utilise emerging intrusion prevention technologies as defined as best practice by the Intrusion Prevention manufacturer.

8.9.5.4. Intrusion prevention system policy must be formally reviewed at least annually.

8.9.5.5. Intrusion prevention system signatures must be set to update automatically.

8.9.5.6. Intrusion prevention systems must be:

- Managed using a centralised management console with change tracking capability.
- Deployed in a high availability configuration.

8.9.5.7. Make use of malware analysis / sandbox features if available.

8.9.6 Gateway and WAN Edge Connectivity

8.9.6.1. Gateway and WAN edge routers/firewalls must be configured with the following controls:

- Apply access control lists (ACLs) to filter traffic required traffic.
- Out of band management port with ACLs.
- Disable unused services.
- Highly available.

8.9.6.2. Gateway and WAN edge routing services are critical for maintaining connectivity between NPCJ and external networks. Any change to edge routing configuration or devices involved in edge routing, must be part of the formal Change Management Process and have the appropriate authorisation before the change is implemented.

8.9.6.3. Where appropriate manufacturer best practice must be applied to the configuration of all WAN edge routing services, for example, Cisco guidance on control plane protection and securing Border Gateway Protocol (BGP).

8.9.7 Connections to un-trusted and third-party networks

8.9.7.1. Any connection between NPCJ networks and any third-party network may increase the risk to NPCJ systems and information. All connections to third party networks must connect through one or more security enforcement points and be approved through the NPCJ Change Management Process.

8.9.8 Security of core network services

8.9.8.1. Domain Name Services

Domain Name Services (DNS) available on the Internet are high-risk. Steps must be taken to configure Internet DNS services to restrict common DNS-based attacks, for example:

- a. Zone transfer attacks that will provide attackers with useful information on network configuration and topology.
- b. Zone changes that could allow domain hi-jacking that could have a high impact on external access to NPCJ systems.
- c. Internal and external DNS servers must be used and hosted on segregated infrastructure.
- d. The configuration of DNS servers must be regularly checked for configuration changes, vulnerabilities and treated as high priority if anything out of the ordinary is discovered.
- e. DNS services must be both IPv4 and IPv6 compliant.

8.9.9 Network Time Protocol

Network Time Protocol (NTP) provides a common time source to all NPCJ IT services so that all device and system clocks can be synchronised. The NTP source must be accurate and reliable for use by cryptographic services, to allow NPCJ to record events in a time-consistent way and to allow correlation of events both internally and externally during incidents and investigations.

- 8.9.9.1. The network must provide a reference clock source based on the NTP that is available to all NPCJ IT services.
- 8.9.9.2. The NTP service must be based on at least NTP version 4 and synchronised to a 'known- good/reputable' external time reference source (e.g., stratum 1, 2 or 3)

8.9.9.3. As incident response relies on accurate timestamps from devices, loss of the NTP service must be progressed via the incident management process.

8.9.9.4. Internal NTP services must:

- Not be accessible from the Internet.
- Be deployed in a high availability configuration.

8.9.10 Secure network management

8.9.10.1. Dedicated management stations (jump box) must be configured to access the devices for management activities only. These stations must be hardened and locked down.

8.9.10.2. Access control lists must be applied to only allow management traffic between the network management stations and the intended end devices. These access control lists apply to both network devices and network servers. For example, TCP wrappers configured on Unix servers or Cisco ACLs on Cisco network devices.

8.9.10.3. Access to network management facilities

8.9.10.4. Network devices are required to support centralised authentication for access control to the device. Acceptable but not limited protocols are:

- LDAP over SSL (LDAPS).
- RADIUS.
- TACACS(+).
- TLS/SSL.

8.9.10.5. Network device failure due to misconfiguration or user error may have a critical impact on NPCJ's ability to do business. Administrative access to network devices must be restricted to an approved list of personnel with appropriate skills and qualifications.

8.9.10.6. Administration access must use cryptographically secure protocols such as SSH or HTTPS.

8.9.10.7. Login access for all accounts must be locked as per the User access management standard.

8.9.10.8. All administrative access to network devices must be logged and monitored according to the Logging and Monitoring Standard.

- 8.9.10.9. Administrative passwords and other authentication tokens for accessing network equipment must be treated as sensitive information.
- 8.9.10.10. Unused services and interfaces must be disabled, for example HTTP management services
- 8.9.10.11. Port-locking must be configured on critical network and security infrastructure to prevent attacks based on physical access. Management interfaces are exempt.
- 8.9.10.12. Local fall back/safe accounts must be stored in a secure location in the event of all users being locked out of devices. This location must be monitored and reported on.
- 8.9.10.13. All devices must be monitored by a management station such as an SNMP manager. Consider using secure management protocols such as SNMPv3 with authentication and encryption.

8.9.11 Network configuration management and integrity checking

- 8.9.11.1. Network devices are key security controls. All network infrastructure devices must be under a formal configuration and change management regime.
- 8.9.11.2. It must be possible to verify the integrity of network device configurations, for example by the use of automated integrity checking solutions or by comparison to a baseline configuration. The integrity of network devices must be checked on a regular basis.
- 8.9.11.3. If a network device is discovered to be incorrectly configured, this must be treated as a Security Incident and investigated and resolved according to the ITSS_03 Security Incident Management Standard.
- 8.9.11.4. All network devices must be backed up according to ITSS_01 Data Backup Standard

8.9.12 Security of wireless networks

- 8.9.12.1. Wireless endpoints must be configured to only permit authenticated and encrypted data:
 - WPA-2 must be used to encrypt traffic on wireless links (WEP and MAC filtering are not satisfactory controls).
 - End points must be authenticated.

- The use of 802.1x technology with certificate-based authentication to the access point is considered appropriate.
- 8.9.12.2. The emanation range of wireless networks must be both considered and tested when designing and implementing wireless networks that connect to NPCJ networks.

8.9.13 Security of Voice over IP (VoIP) networks

- 8.9.13.1. VoIP terminals must only be configurable and display configuration information after end user authentication on the terminal (e.g., username/password)
- 8.9.13.2. VoIP servers must be hardened and patched. Servers must be configured to:
- Disable “auto registration” of VoIP terminals and allow only registered VoIP phones.
 - Enforce a password complexity of 4 or more.
 - Disable all service and testing codes.
 - Harden and limit software loading on VoIP terminals.
- 8.9.13.3. Access to web based interfaces (e.g. client web management, voicemail web interface etc) must be restricted.
- 8.9.13.4. VoIP networks must be segregated from NPCJ data networks (VLAN separation is acceptable).
- 8.9.13.5. Insecure VoIP protocols must not be allowed on data networks.
- 8.9.13.6. VoIP rules/signatures must be established on next generation firewalls to inspect the traffic.
- 8.9.13.7. If call recording is required the *Privacy Act 1988* should be consulted. The general rule is that the call may not be recorded. There are exceptions in limited circumstances, including where a warrant applies. If a call is to be recorded or monitored, an organisation must advise you at the beginning of the conversation so that you have the chance to either end the call, or ask to be transferred to another line where monitoring or recording does not take place
- 8.9.13.8. To combat the misuse of the VoIP environment resulting in financial loss (Toll fraud), all VoIP activities must be logged. In particular this includes:
- Device registration events.

- Call metadata.

8.9.13.9. Where appropriate, sensitive VoIP traffic must be encrypted (note that encryption may negatively affect performance).

8.9.13.10. All VoIP equipment must be configured in line with vendor best practices as described in the overarching security principle security by design.

9 Legislative Authority/Guiding Principles

- The Access to Information Act, 2002
- The Cybercrimes Act, 2015
- The Data Protection Act, 2020
- National Cyber Security Strategy
- Government of Jamaica Information and Communications Technology (ICT) Policy 2011
- GOJ ICT Policies, Standards & Guidelines, February 2018
- JCF ICT Policy & Standard Operating Procedures, 2021